



Designing the DORA/NIS2 Audit Program: A Lead Auditor's Perspective

INTEGRATING REGULATORY COMPLIANCE AND RISK MANAGEMENT FOR
ENHANCED DIGITAL RESILIENCE



Purpose of DORA and NIS2 Audits

Strengthen digital infrastructures and protect stakeholder interests

- Audit programs foster continuous improvement within organizations

Influence organizational risk assessment and credibility building

- Audits adapt to evolving regulatory requirements

Go beyond technical compliance routines or checklists

- Audits create real, lasting impacts on security culture

Emphasize lead auditor's broader responsibilities

- Lead auditor ensures controls are effective in practice





Foundations of Audit Scoping

Audit scoping defines audit boundaries and areas of focus

- Scope includes domains, processes, and systems in play

Identify relevant regulatory requirements under review

- DORA and NIS2 requirements must be considered

Assess all business units and third-party relationships included

- Review policies, inventories, and stakeholder input

Lead auditor engages with stakeholders to clarify boundaries

- May challenge organizational assumptions about scope

Risks of Insufficient or Excessive Audit Scope

Inadequate scope exposes organizations to significant risks

- Critical systems or services may be omitted from audit

Excessively broad scope wastes resources and dilutes focus

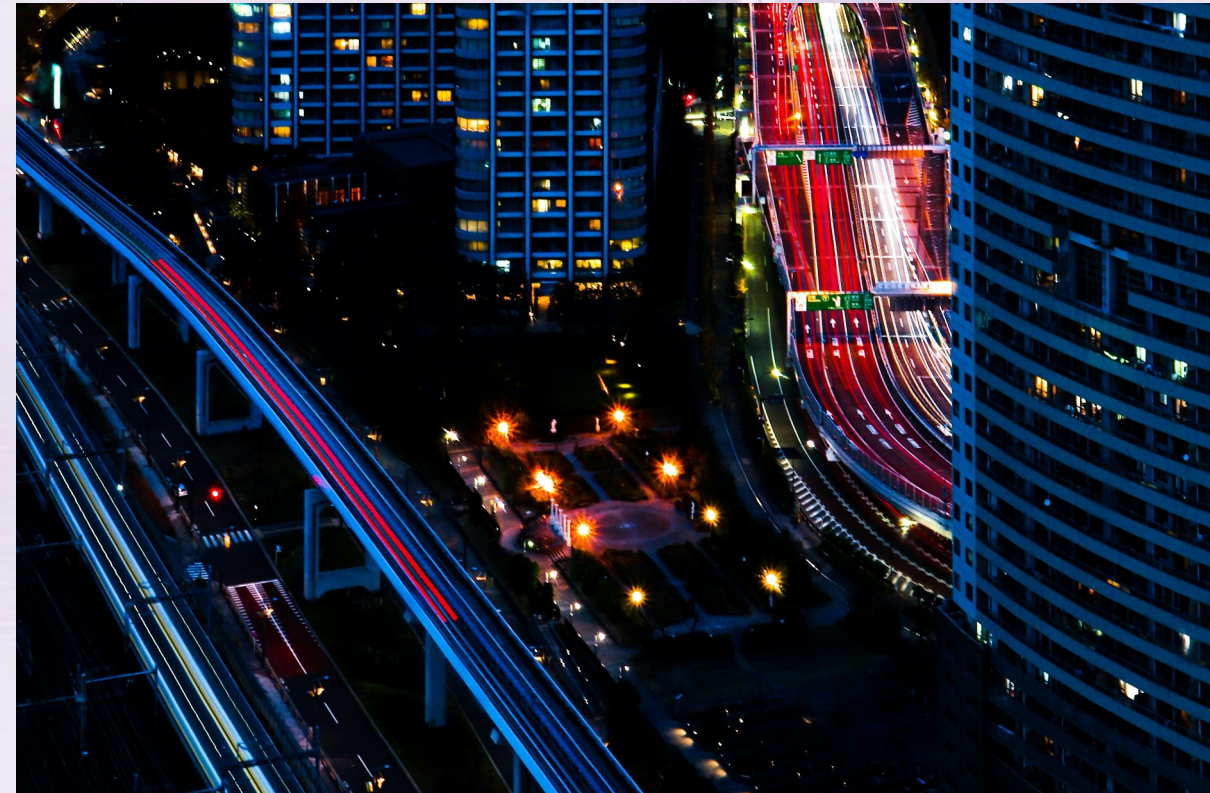
- Over-inclusion may hinder meaningful results

Balanced scope ensures appropriate comprehensiveness

- Lead auditor must balance efficiency and thoroughness

Critical third-party or cloud services must not be missed

- Inclusion prevents possible “blind spots” in resilience



Principles of Audit Sampling

Sampling selects specific controls and processes for review

- Based on risk and representativeness, not arbitrary choice

Must be guided by criticality, incident history, and complexity

- Assess likelihood of control failure in selection

Use real examples, such as incident response sampling

- Focus on high-impact incidents and recurring issues

Sufficient evidence is gathered without overwhelming teams

- Aim for reliable conclusions, not data overload



Challenges and Responsibilities in Sampling

Poor sampling risks missing significant weaknesses

- Critical issues may go undetected if sample not well-chosen

Over-sampling can cause analysis paralysis

- Too much data clouds auditor judgment and efficiency

Lead auditor tailors sampling strategy by context

- Approach must adjust as new information emerges

Rationale and strategy should be communicated transparently

- Stakeholders need to understand selection methods



Handling Non-Conformities Systematically

Identify and assess significance of non-conformities found

- Not all instances carry the same risk or impact

Minor lapses differ from fundamental cyber resilience gaps

- Example: Untested disaster recovery is a serious DORA deficiency

Findings should be precise, evidence-based, and constructive

- Clearly state issue, context, implications, and observations

Use specific examples to highlight impact and needed actions

- Delayed patches risk data breaches and operational continuity

Remediation and Partnership Approaches

Prioritize remediation and set realistic deadlines

- Collaborate on actionable plans for non-conformities

Monitor progress and support organizational improvement

- Audits drive more than fault-finding; enable positive change

Work with IT and compliance teams on targeted solutions

- Address gaps, such as third-party risk management issues

Partnership shifts audit from compliance to transformation

- Cooperative approach builds sustainable resilience



Organizational and Cultural Impacts of Audits

Audits influence compliance outcomes and organizational culture

- Unexpected weaknesses prompt transformative lessons

Engagement and improvement drive lasting change

- Effective handling leads to measurable progress

Reflect on past experiences of non-conformity response

- Responses shape future culture and outcomes

Key moments pivot organizations toward accountability

- Audits become catalysts for resilience and trust



Beyond Compliance: Audit as Catalyst for Trust

Ultimate aim: foster resilient, adaptive, transparent organizations

- Audit findings motivate shifts in mindset and culture

Controls seen as enablers, not burdens

- Inspire trust and stability among teams and stakeholders

Non-conformity findings drive reviews of vendor practices

- Improvement seen in access management, contracts, monitoring

Benefits extend beyond regulatory requirements

- Reduced operational risk and increased partner confidence



Skills and Qualities of Effective Lead Auditors

Combine technical knowledge and interpersonal skill

- Navigate regulations and adapt methodologies competently

Build rapport and foster openness with stakeholders

- Encourage a spirit of learning in audit engagements

Analytical rigor paired with empathy ensures success

- Recognize people behind every process and control

Adapt to varied contexts and interpret nuanced requirements

- Lead auditor acts as both expert and communicator

Case Study: Audit Drives Organizational Change

Pan-European bank relies on legacy external platform

- Robust internal controls contrasted by vendor dependencies

Sampling uncovers incident protocol non-conformity

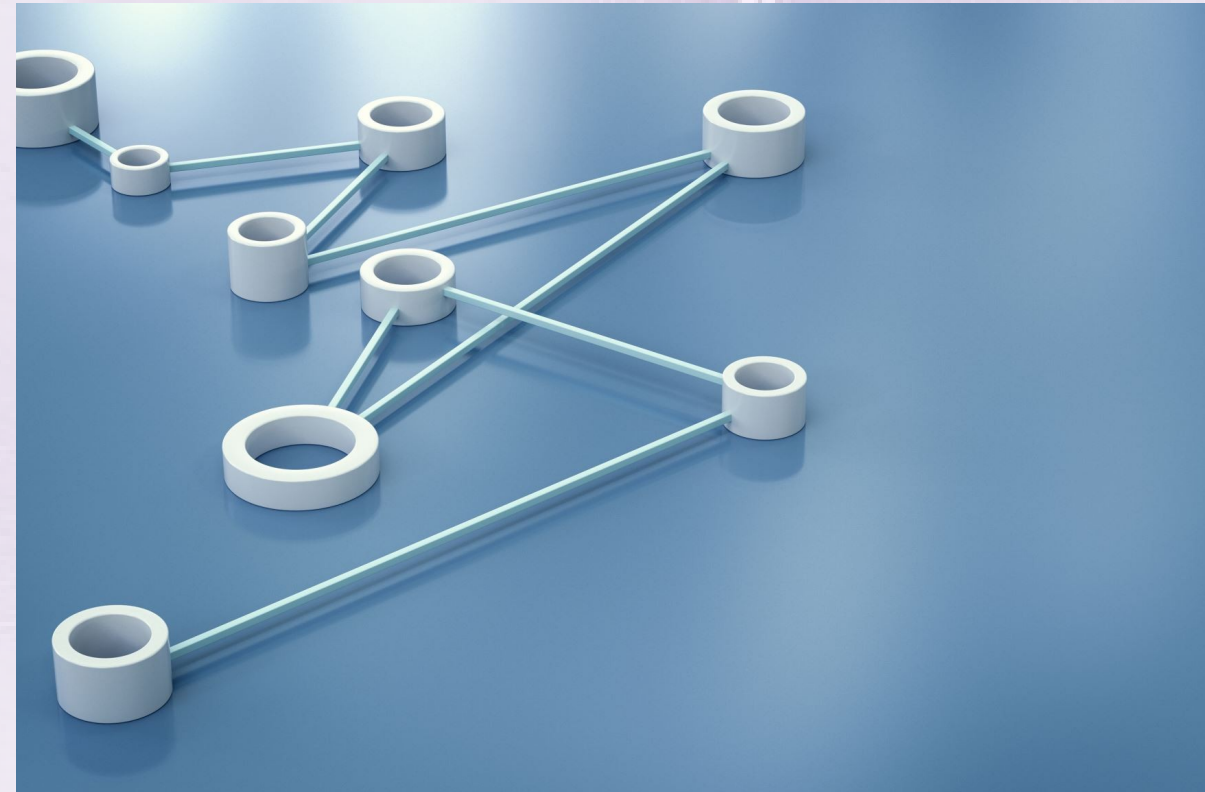
- Documented finding highlights risks in response timeliness

Leadership responds by overhauling vendor oversight

- Enhancements in incident reporting and training follow

Actions lead to culture of accountability and ongoing improvement

- Non-conformity finding shifts organizational attitudes



Overcoming Common Audit Challenges

Resistance to scope expansion or data access is common

- Business units may push back on audit inclusions

Wise auditors anticipate hurdles and seek pragmatic solutions

- Communication and evidence can ease resistance

Reinforce shared goal of organizational protection

- Present regulatory expectations and associated risks

Learning from past audits optimizes future approaches

- Document reviews alone may be insufficient for accuracy



Planning for Impactful Audit Execution

Prioritize scoping based on organizational context and needs

- Balance audit depth with resource and time constraints

Employ strategies to ensure non-conformities drive change

- Focus on not just recording, but addressing issues

Meaningful engagement leads to ongoing organizational improvement

- Learning from audits should drive future resilience

Summary of Audit Program Essentials

Scoping defines clear, risk-based audit boundaries

- Focus on the most critical areas for review

Sampling targets significant, representative processes for testing

- Ensures that findings are actionable and meaningful

Non-conformity handling centers on remediation and partnership

- Drive improvement, not just documentation

Technical and human impacts shape resilience and trust

- Effective audits catalyze lasting organizational change

